

Rapport de sécurité — SecureScan

Projet : <https://github.com/nicoopo/SecureScan> | Date : 15/05/2026 à 12:49 | Langage : unknown

Score global

0/100

Résumé

18 Critique	10 Haute	30 Moyenne	2 Basse
----------------	-------------	---------------	------------

Vulnérabilités détectées

Fichier	Ligne	Description	Sévérité	OWASP
.env	34	L'URL de connexion à la base de données contient un mot de passe trivial ou par défaut. Utiliser un mot de passe fort unique par environnement.	HIGH	A02
.env	35	L'URL de connexion à la base de données contient un mot de passe trivial ou par défaut. Utiliser un mot de passe fort unique par environnement.	HIGH	A02
.env	36	L'URL de connexion à la base de données contient un mot de passe trivial ou par défaut. Utiliser un mot de passe fort unique par environnement.	HIGH	A02
src/DataFixtures/FindingFixtures.php	231	Un mot de passe, secret ou clé d'API semble être écrit en dur dans le code. Utiliser des variables d'environnement et ne jamais committer des secrets dans le dépôt.	HIGH	A02
src/Service/Analyzer/A02Analyzer.php	26	phpinfo() expose des informations sensibles : version PHP, extensions chargées, chemins système et variables d'environnement. Supprimer de tout code destiné à la production.	CRITICAL	A02

Fichier	Ligne	Description	Sévérité	OWASP
src/Service/Analyzer/A02Analyzer.php	27	phpinfo() expose des informations sensibles : version PHP, extensions chargées, chemins système et variables d'environnement. Supprimer de tout code destiné à la production.	CRITICAL	A02
src/Service/Analyzer/A02Analyzer.php	42	E_ALL active tous les niveaux d'erreur PHP. Acceptable uniquement en développement. En production, logger les erreurs côté serveur sans les afficher à l'utilisateur.	MEDIUM	A02
composer.json	1	La dépendance ext-ctype utilise "*". Fixer une version précise.	MEDIUM	A03
composer.json	1	La dépendance ext-iconv utilise "*". Fixer une version précise.	MEDIUM	A03
src/Service/Analyzer/A04Analyzer.php	49	rand() et mt_rand() ne sont pas cryptographiquement sûrs. Utiliser random_bytes() ou random_int().	MEDIUM	A04
src/DataFixtures/FindingFixtures.php	83	Une variable est concaténée directement dans une requête SQL. Utiliser des requêtes préparées avec des paramètres liés.	CRITICAL	A05
src/DataFixtures/FindingFixtures.php	83	Une variable PHP est concaténée dans une requête SQL brute. Risque d'injection SQL. Utiliser PDO avec prepare()/execute().	CRITICAL	A05
config/packages/security.yaml	18	Une configuration désactive potentiellement une protection de sécurité importante.	HIGH	A06
src/Controller/Admin/DashboardController.php	16	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06
src/Controller/Admin/DashboardController.php	20	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06
src/Controller/Admin/DashboardController.php	25	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06
src/Controller/Admin/DashboardController.php	38	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06

Fichier	Ligne	Description	Sévérité	OWASP
src/Controller/Admin/DashboardController.php	40	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06
src/Controller/Admin/DashboardController.php	42	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06
src/Controller/Admin/DashboardController.php	44	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06
src/Controller/Admin/DashboardController.php	46	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06
src/Controller/Admin/DashboardController.php	48	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06
src/Controller/Admin/ScanCrudController.php	122	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06
src/Controller/ForgotPasswordController.php	11	Une route Symfony a été détectée sans vérification explicite de sécurité.	MEDIUM	A06
src/Controller/HomeController.php	10	Une route Symfony a été détectée sans vérification explicite de sécurité.	MEDIUM	A06
src/Controller/LoginController.php	12	Une route Symfony a été détectée sans vérification explicite de sécurité.	MEDIUM	A06
src/Controller/LoginController.php	27	Une route Symfony a été détectée sans vérification explicite de sécurité.	MEDIUM	A06
src/Controller/RegisterController.php	11	Une route Symfony a été détectée sans vérification explicite de sécurité.	MEDIUM	A06
src/Controller/RegistrationController.php	16	Une route Symfony a été détectée sans vérification explicite de sécurité.	MEDIUM	A06
src/Controller/RegistrationController.php	20	Un formulaire Symfony est utilisé sans validation explicite détectée.	LOW	A06
src/Controller/ReportController.php	19	Une route Symfony a été détectée sans vérification explicite de sécurité.	MEDIUM	A06
src/Controller/ReportController.php	29	Une route Symfony a été détectée sans vérification explicite de sécurité.	MEDIUM	A06
src/Controller/ReportController.php	43	Une route Symfony a été détectée sans vérification explicite de sécurité.	MEDIUM	A06

Fichier	Ligne	Description	Sévérité	OWASP
src/Controller/ScanController.php	28	Un upload de fichier a été détecté sans validation explicite du type MIME, de la taille ou de l'extension.	HIGH	A06
src/Controller/ScanController.php	16	Une route Symfony a été détectée sans vérification explicite de sécurité.	MEDIUM	A06
src/Controller/ScanController.php	44	Une route Symfony a été détectée sans vérification explicite de sécurité.	MEDIUM	A06
src/Controller/ScanController.php	57	Une route Symfony a été détectée sans vérification explicite de sécurité.	MEDIUM	A06
src/Controller/ScanController.php	20	Un formulaire Symfony est utilisé sans validation explicite détectée.	LOW	A06
src/Service/Analyzer/A08Analyzer.php	61	Un upload de fichier a été détecté sans validation explicite du type MIME, de la taille ou de l'extension.	HIGH	A06
templates/admin/dashboard.html.twig	9	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06
templates/admin/dashboard.html.twig	10	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06
templates/admin/dashboard.html.twig	11	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06
templates/admin/dashboard.html.twig	12	Une fonctionnalité admin a été détectée sans contrôle explicite de rôle.	CRITICAL	A06
config/reference.php	1135	Une fonctionnalité remember me est détectée. Vérifier que les tokens persistants sont hachés en base et ont une expiration.	MEDIUM	A07
config/reference.php	1158	Une fonctionnalité remember me est détectée. Vérifier que les tokens persistants sont hachés en base et ont une expiration.	MEDIUM	A07
config/reference.php	1186	Une fonctionnalité remember me est détectée. Vérifier que les tokens persistants sont hachés en base et ont une expiration.	MEDIUM	A07

Fichier	Ligne	Description	Sévérité	OWASP
config/reference.php	1197	Une fonctionnalité remember me est détectée. Vérifier que les tokens persistants sont hachés en base et ont une expiration.	MEDIUM	A07
config/reference.php	1213	Une fonctionnalité remember me est détectée. Vérifier que les tokens persistants sont hachés en base et ont une expiration.	MEDIUM	A07
config/reference.php	1270	Une fonctionnalité remember me est détectée. Vérifier que les tokens persistants sont hachés en base et ont une expiration.	MEDIUM	A07
config/reference.php	1277	Une fonctionnalité remember me est détectée. Vérifier que les tokens persistants sont hachés en base et ont une expiration.	MEDIUM	A07
config/reference.php	1283	Une fonctionnalité remember me est détectée. Vérifier que les tokens persistants sont hachés en base et ont une expiration.	MEDIUM	A07
config/reference.php	1284	Une fonctionnalité remember me est détectée. Vérifier que les tokens persistants sont hachés en base et ont une expiration.	MEDIUM	A07
config/reference.php	1291	Une fonctionnalité remember me est détectée. Vérifier que les tokens persistants sont hachés en base et ont une expiration.	MEDIUM	A07
config/reference.php	1292	Une fonctionnalité remember me est détectée. Vérifier que les tokens persistants sont hachés en base et ont une expiration.	MEDIUM	A07
src/Service/Analyzer/A09Analyzer.php	59	Une vérification de mot de passe est détectée sans limitation de tentatives. Implémenter un rate limiting ou un blocage après N échecs.	HIGH	A07
templates/components/auth/login_form.html.twig	1	Un formulaire POST ne semble pas avoir de token CSRF. Utiliser des tokens CSRF pour protéger les formulaires.	HIGH	A07

Fichier	Ligne	Description	Sévérité	OWASP
templates/components/auth/signup_form.html.twig	1	Un formulaire POST ne semble pas avoir de token CSRF. Utiliser des tokens CSRF pour protéger les formulaires.	HIGH	A07
src/Service/Analyzer/A09Analyzer.php	10	error_reporting(0) masque toutes les erreurs. Les erreurs doivent être loggées côté serveur même si elles ne sont pas affichées.	MEDIUM	A10
src/Service/Analyzer/A09Analyzer.php	44	error_reporting(0) masque toutes les erreurs. Les erreurs doivent être loggées côté serveur même si elles ne sont pas affichées.	MEDIUM	A10
src/Service/Analyzer/A09Analyzer.php	45	error_reporting(0) masque toutes les erreurs. Les erreurs doivent être loggées côté serveur même si elles ne sont pas affichées.	MEDIUM	A10